



TECHNICAL DOCUMENTATION

Security & Compliance Whitepaper

Formicanera Agent Management System — Architecture, data protection measures, GDPR and NIS2 compliance documentation addressed to the IT and Legal/Compliance teams of Gebr. Brasseler GmbH & Co. KG.

- Non-Interference Principle with the Komet ERP — RPA methodology explained
- Technical security measures: MFA, AES-256-GCM, immutable audit trail, RBAC
- GDPR compliance: roles, legal basis, data subjects' rights implementation
- NIS2 (Directive 2022/2555) control mapping — Article 21 compliance

DOCUMENT DATE

May 2026

VERSION

2.0 — Final

ADDRESSED TO

Alexander Lange, IT
Gebr. Brasseler GmbH &
Co. KG

PREPARED BY

Francesco Formicola
Developer — Formicanera

1. Contractual Context and GDPR Roles

Before addressing technical measures, it is important to establish the legal framework that governs all data processing performed by Formicanera — and the precise roles of each party under GDPR.

Gebr. Brasseler GmbH & Co. KG / Komet Italia S.r.l. — Data Controller

As defined under **Art. 4(7) GDPR**, Komet Italia S.r.l. determines the purposes and means of processing personal data of agents and customers within the Komet commercial network. Gebr. Brasseler, as parent company, exercises oversight over compliance practices of entities within the Komet group.

Formicanera — Data Processor

As defined under **Art. 28 GDPR**, Formicanera processes personal data exclusively on behalf of, and under documented instructions from, Komet Italia S.r.l. This is the same standard model used by Salesforce, Microsoft 365, Google Workspace, and every major enterprise SaaS provider operating in Europe.

Key Structural Points

- ✓ A **Data Processing Agreement (DPA)** compliant with Art. 28 GDPR will be formally signed before the system goes live — exactly as required by the Regulation and as standard practice across the SaaS industry.
- ✓ The commercial agent's ERP credentials are **assigned by Komet Italia S.r.l.** — all automated operations performed by Formicanera remain strictly within the agent's authorized scope as defined by Komet Italia.
- ✓ Formicanera processes **no data outside the scope of the agency relationship** . Customer data, order history, and financial documents are processed solely to fulfil the agent's contractual commercial activities.
- ✓ All data remains within the **European Union** at all times. No international transfers take place outside the framework of EU Standard Contractual Clauses.
- ✓ The **Komet ERP remains the authoritative record** of all transactions. Formicanera does not create a parallel data authority — it synchronizes a read-optimized view for field use.

Industry context: The Controller/Processor model is not a legal construct unique to Formicanera — it is the standard architecture underlying every B2B SaaS deployment in Europe. Salesforce, SAP, and Microsoft operate under identical GDPR frameworks when processing data on behalf of their enterprise customers. What distinguishes Formicanera is the narrow, well-defined scope of processing: a single agent's commercial data, never aggregated across agents, never shared with third parties outside the documented sub-processor list.

2. The Non-Interference Principle with the Komet ERP

This is the most operationally significant section of this document. The question of ERP integrity is at the core of any responsible IT review, and it deserves a precise, verifiable answer.

What Formicanera Actually Does

Formicanera does not bypass the ERP. It automates exactly what the agent already does manually.

Concretely: a standard Chromium browser authenticates into the Komet ERP Archibald using **Mr. Formicola's personal agent credentials** — the same credentials Komet Italia assigned to him for his commercial work. The system then navigates the same interface screens the agent would navigate manually, reading order data, customer records, and official documents such as invoices and delivery notes. When the agent submits an order through the Formicanera PWA, the browser fills in the ERP order form using those same credentials and submits it through the standard ERP interface.

No elevated permissions

The system uses only the standard agent role within the ERP. It has no administrative access, no access to configuration screens, and no ability to modify ERP settings or access other agents' data.

No shared credentials

Each agent's ERP credentials are used exclusively by that agent's automated session. There is no pooled or shared credential set. Cross-agent access is architecturally impossible.

No data outside authorized scope

The system sees exactly what the agent sees — not a byte more. It cannot access territories, customers, or documents that the agent cannot access manually through the standard ERP interface.

ERP as the record of truth

All order submissions flow into the Komet ERP as the authoritative system. Formicanera does not create a parallel transaction record — it provides a read-optimized mobile interface over the ERP's own data.

What This Technique Is — and What It Is Not

This is **RPA — Robotic Process Automation**: an industry-standard technique used by enterprises worldwide, equivalent in nature to a user operating software via keyboard shortcuts, scripting, or an accessibility tool. RPA is explicitly recognized by leading industry frameworks (ISO/IEC, ENISA) as a legitimate automation technique that operates entirely within the bounds of existing user authorization.

This does not constitute unauthorized computer access under Directive 2013/40/EU on attacks against information systems, nor under §202a StGB (German Criminal Code on unauthorized data access). The underlying access authorization — Mr. Formicola's agent credentials and his contractual right to use the Komet ERP, as granted by Komet Italia S.r.l. — is valid, current, and formally documented in the agency agreement dated January 1, 2026.

"Think of Formicanera as an experienced, disciplined version of the agent himself — one that accesses the ERP at predictable intervals, never forgets to log out, and generates **no more load than a human working at their desk**. It does not introduce new access; it makes existing, authorized access more consistent and reliable."

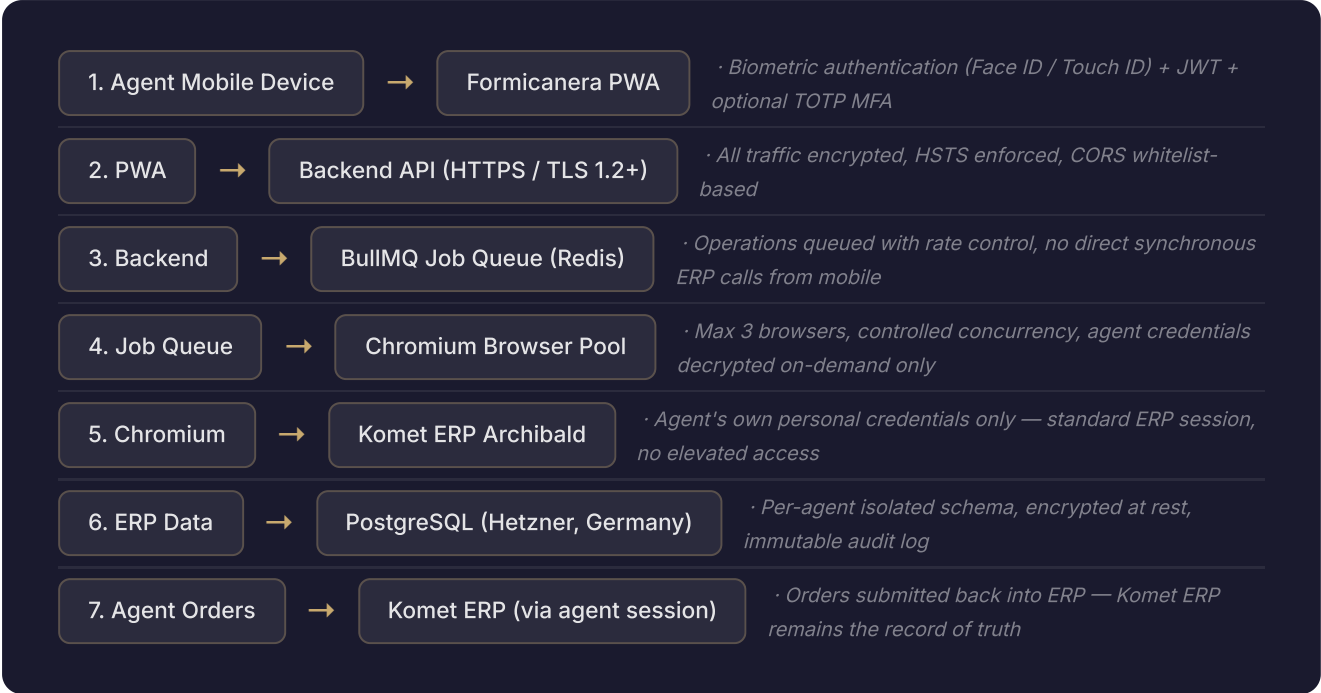
ERP Load and Performance Protection

- ✓ **Less erratic than a human user:** automated interactions are spaced with mandatory intervals, preventing any burst of requests that a busy human agent might inadvertently generate.
- ✓ **Automatic suspension on ERP unavailability:** if the ERP is unresponsive, under maintenance, or experiencing issues, the system detects this immediately and suspends all interaction without aggressive retry loops.
- ✓ **Activity-aware synchronization:** when the agent is inactive (evenings, weekends), synchronization frequency automatically decreases, further reducing ERP interaction during off-hours.
- ✓ **No ERP performance degradation observed:** during the entire operational period, no performance impact attributable to the Formicanera system has been recorded on the Komet ERP.
- ✓ **Data integrity protection:** if an ERP query returns no results for any reason (including transient network conditions), existing local data is preserved — the system never overwrites valid records with empty responses.

3. Data Flow Architecture

The following describes the complete end-to-end data flow, from the agent's mobile device to the Komet ERP and back, with all security controls at each boundary.

Step-by-Step Data Flow



Key Architectural Properties

All data stored in Germany (EU)

The production server is a Hetzner CPX32 VPS located in Falkenstein, Germany. Object Storage backups use Hetzner's fsn1 region (Frankfurt, Germany). No data is stored outside the European Union.

Per-agent data isolation

Each agent's data is stored in an isolated schema. There is no shared data layer between agents — a bug, misconfiguration, or compromised session for one agent cannot expose another agent's data.

No mobile-to-ERP direct path

The agent's mobile device never communicates directly with the ERP. All ERP interactions are mediated through the backend server, providing a clean security boundary and complete audit trail.

ERP as authoritative source

Agent-initiated orders flow back into the Komet ERP through the standard submission interface. Komet Italia retains full authority over order acceptance or rejection, consistent with Article 2(g) of the agency agreement.

4. Technical Security Measures Implemented

The following security measures are currently implemented in production, operative since April 2026, and documented in the Technical Conformity Declaration (n. 2026-001).

4.1 — Authentication & Session Management

JWT with Active Revocation (Redis blacklist): The system implements JWT access tokens with a cryptographically unique identifier (jti, UUID v4) per token. At logout, the jti is inserted into a Redis revocation list with dynamic TTL calculated from token expiry. The authentication middleware verifies revocation on every request. Stolen tokens are invalidated the moment the agent logs out.

MFA TOTP (RFC 6238): Multi-factor authentication is implemented using Time-based One-Time Passwords. The TOTP secret is encrypted with AES-256-GCM before database persistence — it is never accessible in plaintext, never transmitted in API responses. Eight single-use recovery codes are provided, bcrypt-hashed in storage. The MFA setup endpoint is rate-limited (5 requests / 15 minutes per IP).

MFA Device Trust (30-day exemption): To reduce friction while maintaining security, a trusted-device token (SHA-256 hash stored in database) allows skipping OTP for up to 30 days on a verified device. The trust relationship is device-specific and revocable from the admin panel.

Biometric Authentication (WebAuthn): The PWA integrates Face ID and Touch ID via the native OS WebAuthn API. Biometric data is processed exclusively by the device's secure enclave — it is never transmitted to the server, never stored server-side, and never accessible to the application layer. The server receives only a cryptographic attestation of successful local biometric verification.

4.2 — Rate Limiting on All Sensitive Endpoints

Endpoint	Window	Limit	Response on Breach
POST /api/auth/login	15 minutes	5 attempts	HTTP 429 + audit log entry
POST /api/auth/refresh	60 minutes	20 requests	HTTP 429
POST /api/auth/mfa-verify	15 minutes	10 attempts	HTTP 429
POST /api/auth/mfa-setup	15 minutes	5 requests	HTTP 429
POST /api/auth/mfa-confirm	15 minutes	5 requests	HTTP 429

Every login threshold breach is recorded in the immutable audit log with actor IP, user agent, and timestamp.

4.3 — Encryption

- ✓ **AES-256-GCM at rest** for ERP credentials and MFA secrets — the same encryption standard used in financial services applications. Key derivation uses PBKDF2-HMAC-SHA256. The encryption key is stored exclusively as an environment variable, never in source code, never in logs, never transmitted in any API response.
- ✓ **TLS 1.2+ in transit** for all communications between mobile client and backend server — managed by Nginx with automatically renewed Let's Encrypt certificates. There is no unencrypted data path.
- ✓ **HSTS enforcement** prevents protocol downgrade attacks. All HTTPS connections are mandated at the transport layer.

- ✓ **No secrets in source code** — all cryptographic keys, database credentials, and API tokens are managed as environment variables in the production container environment.

4.4 — Access Control (RBAC)

The system implements four role levels with per-user module permissions:

Role	Scope	MFA
admin	Full access including admin panel, audit log, user management	Optional
office	Advanced operational access (invoices, DDT, full history)	Optional
agent	Standard agent access: own customers, own orders, products	Optional
dealer	Dealer access: Fresis order history and customer subset	Optional

Each user additionally holds a per-user module array (`modules` JSONB) that restricts access to specific functional areas. Module assignment is managed exclusively by administrators. An admin cannot accidentally lock themselves out (self-role guard).

4.5 — HTTP Security Headers

- ✓ **Strict-Transport-Security (HSTS)** with long max-age
- ✓ **Content-Security-Policy (strict):** `default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data;; connect-src 'self' wss;; object-src 'none'; frame-src 'none'`
- ✓ **X-Frame-Options: DENY** — prevents clickjacking attacks
- ✓ **X-Content-Type-Options: nosniff** — prevents MIME-type sniffing
- ✓ **CORS whitelist:** `cross-origin requests accepted https://formicanera.com` — all other origins are rejected at the middleware level
only from

4.6 — Immutable Audit Trail

The system maintains a persistent, append-only audit log in `system.audit_log` (PostgreSQL). Database-level immutability is guaranteed by:

`REVOKE UPDATE, DELETE ON system.audit_log FROM archibald` — the application database user is structurally prevented from modifying or deleting any audit record. Removal of records would require direct superuser access with separate credentials not used by the application.

Events tracked in the audit log:

- ✓ All login attempts (successful and failed), logouts, token revocations
- ✓ Order creation, modification, deletion (individual and batch)
- ✓ GDPR erasure (Art. 17) and data export (Art. 20) operations — with actor ID and timestamp
- ✓ User management operations (role assignment, module changes, MFA configuration)
- ✓ Security alerts: repeated failed logins, circuit breaker activation, rate limit breaches, high-rate system errors

4.7 — CI/CD Security Gate

The continuous integration pipeline (GitHub Actions) executes `npm audit --audit-level=critical` on every push to the repository. Critical vulnerabilities block both the build and the automatic deployment. The software cannot be distributed to production with known critical vulnerabilities in its dependencies.

5. GDPR Compliance

Formicanera processes personal data as a Data Processor under Art. 28 GDPR. The following documents the categories of data processed, the legal bases, and the implementation of data subjects' rights.

5.1 — Categories of Personal Data Processed

Agent data

Full name, login credentials (bcrypt-hashed password), encrypted ERP credentials, MFA configuration (encrypted TOTP secret), assigned role and modules, activity logs (rolling 90-day retention). No special category data under Art. 9 GDPR.

Customer data

Business name, VAT number, fiscal code, registered address, email address, telephone numbers, order history, invoice records, delivery note records. All data originates from the Komet ERP — Formicanera does not collect customer data independently.

No health data, biometric data (server-side), genetic data, or any other special category data under Art. 9 GDPR is processed. Biometric authentication (Face ID/Touch ID) is processed entirely on-device — no biometric data reaches the server.

5.2 — Legal Bases for Processing

Processing Activity	Legal Basis	GDPR Article
Order management and customer relationship operations	Performance of a contract	Art. 6(1)(b)
Authentication, session management, security monitoring	Legitimate interest (IT security)	Art. 6(1)(f)
VAT number validation	Legal obligation (fiscal compliance)	Art. 6(1)(c)
Audit log retention	Legitimate interest + legal obligation	Art. 6(1)(c)(f)

5.3 — Data Subjects' Rights — Implementation

Right	Implementation	Response Time
Access (Art. 15)	Full data export available via admin panel; audit log of all operations is inspectable	Within 30 days
Erasure (Art. 17)	POST /api/admin/customers/:id/gdpr-erase — anonymizes 19 personal data fields across agents.customers and shared.sub_clients tables. Fields replaced with traceable marker [GDPR_ERASED_<timestamp ISO>]. Structural records (orders, history) retained for fiscal compliance, stripped of identifying references. Operation blocked if active orders exist. Every erasure recorded in audit log with actor ID.	Within 30 days
Portability (Art. 20)	GET /api/admin/customers/:id/export — produces a structured JSON archive containing all customer data: profile, orders, order articles, linked sub-clients. Returned with Content-Disposition: attachment. Every export recorded in audit log.	Within 30 days
Rectification (Art. 16)	Customer records editable by authorized admin/office roles via standard admin interface	Within 30 days
Restriction (Art. 18)	Account deactivation and module restriction available via admin panel; agent data access revocable immediately	Immediately on request

5.4 — Retention Policy

- ✓ **Operational data:** retained for the duration of the contract plus 12 months post-termination (fiscal obligation compliance)
- ✓ **System and application logs:** 90-day rolling retention with automatic size-based rotation
- ✓ **Post-contract erasure:** all agent-related personal data erased within 60 days of contract termination; a structured export is available prior to deletion in accordance with Art. 20 GDPR
- ✓ **Automated retention monitoring:** weekly scan identifies customers inactive for more than 24 months; responsible agent is notified for review (no automatic deletion — deletion remains a deliberate human act)

5.5 — Data Processing Agreement

A Data Processing Agreement fully compliant with Art. 28 GDPR — including all mandatory clauses (subject matter, duration, nature and purpose, categories of data, obligations and rights of the Controller) — will be formally executed before the system goes live. The DPA will be signed concurrently with the commercial contract as a prerequisite for processing activation.

6. NIS2 Compliance

Directive (EU) 2022/2555 (NIS2), transposed in Italy by D.Lgs. 138/2024, requires that suppliers of digital services implement appropriate technical and organizational security measures. The following maps Formicanera's implemented controls against Art. 21 NIS2 requirements.

NIS2 Art. 21 Requirement	Formicanera Implementation
Policies for risk analysis and information system security	Security measures documented in this whitepaper and in Technical Conformity Declaration n. 2026-001. DPIA (Data Protection Impact Assessment) screening completed. Threat model covers authentication, data-in-transit, data-at-rest, and ERP interaction boundaries.
Incident handling	Formal incident response procedure with P1/P2/P3 severity classification. Data Controller notification within 24 hours of P1 incidents. Supervisory authority (Garante/BSI) notification within 72 hours per Art. 33 GDPR. Automatic security alerts for failed logins, circuit breaker, rate limit breaches.
Business continuity and crisis management	Daily automated backups (nightly, 02:00 CET). RPO < 24 hours. RTO 30–60 minutes (database restore + redeploy from GitHub). Backup verification logged on every execution. Full recovery procedure documented.
Supply chain security	Hetzner Online GmbH (ISO 27001 certified, DPA signed) as primary infrastructure provider. FedEx International (Standard Contractual Clauses, EU-compliant) for shipment tracking integration only. Full sub-processor register maintained and available for audit.
Security in acquisition, development and maintenance	<code>npm audit --audit-level=critical</code> runs on every CI/CD push — critical vulnerabilities block deployment. All database queries parameterized (no SQL injection risk). Input validation via Zod on all security-critical API routes. Dependencies reviewed before inclusion.
Policies to assess effectiveness of security measures	Immutable audit log provides continuous operational visibility. Penetration test planned as per SLA agreement with Komet Italia prior to full network rollout. Security review incorporated into deployment workflow.
Cryptography and encryption	AES-256-GCM at rest for all sensitive credentials. TLS 1.2+ in transit with HSTS enforcement. PBKDF2-HMAC-SHA256 for key derivation. bcrypt for password hashing. No deprecated algorithms in use.
Human resources security, access control	RBAC with four roles (admin/office/agent/dealer) + per-user module restrictions. MFA (TOTP) available for all roles. Audit log of all user management operations. Account deactivation immediate on request.
Use of multi-factor authentication	TOTP MFA (RFC 6238) implemented for all system access. Backup recovery codes provided (bcrypt-hashed). Device trust mechanism to reduce friction while maintaining security posture.

Applicability note: As a Data Processor under Art. 28 GDPR supporting a commercial agent's operational activities, Formicanera is committed to maintaining security measures proportionate to the risk profile of the data processed. The controls documented above exceed the baseline requirements for a system of this scale and data sensitivity, reflecting a deliberate architectural commitment to security-by-design rather than compliance-by-checklist.

7. Backup and Business Continuity

Data availability and recoverability are treated as security properties, not operational conveniences. The backup architecture is designed for verifiable, EU-resident resilience.

Backup Frequency

Nightly automated backup executed at 02:00 CET via cron job on the production VPS. Every backup execution is logged and verifiable in the container logs.

Backup Process

pg_dump → gzip compression → encrypted upload to Hetzner Object Storage. Region: fsn1 (Frankfurt, Germany). Storage remains within the EU at all times.

Retention

30-day rolling rotation. Backups older than 30 days are automatically purged. The most recent 30 daily snapshots are always retained.

RPO — Recovery Point Objective

Less than 24 hours. In the event of a catastrophic server failure, data loss is bounded to the last completed backup cycle.

RTO — Recovery Time Objective

30–60 minutes. Database restore from the last backup + fresh application deployment from the GitHub repository. The source code repository is the authoritative deployment source.

Verification

Every backup execution result is logged. Backup integrity can be independently verified by the Controller at any time upon request. Restore drills can be conducted under NDA in a staging environment.

"Backup is not meaningful unless it is tested. We maintain a documented restore procedure and are prepared to demonstrate a full database recovery in a staging environment as part of any technical audit requested by Gebr. Brasseler GmbH & Co. KG."

8. Incident Response

A formal incident response procedure is documented and operative. All incidents are classified by severity, with defined response windows and mandatory notification obligations.

P1 — CRITICAL Data breach or service unavailability > 4 hours Response: < 4 business hours Controller notification: within 24 hours Supervisory authority (Garante / BSI): within 72 hours (Art. 33 GDPR) Post-mortem: documented within 5 business days	P2 — HIGH Service degradation or unauthorized access attempt Response: < 8 business hours Controller notification: within 48 hours if personal data risk exists Scope: authentication failures, circuit breaker activation, unusual ERP patterns	P3 — MEDIUM Non-critical service issues or anomalies Response: 1 business day Controller notification: at next scheduled status update Scope: sync delays, minor performance degradation, non-security functional issues
---	---	--

Automatic Security Alerts

The system generates automatic security.alert events recorded in the immutable audit log for the following conditions:

- ✓ **Repeated failed login attempts** — threshold breach triggers rate limiting and alert generation
- ✓ **Circuit breaker activation** — after 3 consecutive ERP operation failures, all ERP interactions pause automatically pending investigation
- ✓ **Rate limit exceeded** — all rate limit breaches on authentication endpoints are logged with IP address and user agent
- ✓ **High-rate system errors** — unusual error frequency patterns trigger alerts for operational review
- ✓ **ERP unavailability detection** — system suspension events are logged with start time, duration, and recovery confirmation

9. Sub-Processors

Formicanera maintains a complete and current register of all third-party providers that process personal data on behalf of the system. As of the date of this document, the sub-processor list is as follows.

Sub-Processor	Role	Data Processed	Location	Guarantees
Hetzner Online GmbH	VPS hosting + Object Storage (backups)	All system data (at rest)	Falkenstein / Frankfurt, Germany (EU)	ISO 27001 certified. DPA signed. GDPR-compliant data centre operations. No data leaves Germany.
FedEx International	Shipment tracking integration	Tracking numbers only — no personal customer data transmitted	EU / USA	Standard Contractual Clauses (SCCs) — EU Commission approved transfer mechanism. Limited to non-identifying logistics reference data.

No external email service is used for security notifications. All alerts and security events are managed via the internal audit log system. Notifications to the Controller are delivered via documented channels — no personal data transits through third-party email providers for this purpose.

Sub-Processor Governance

- ✓ The full sub-processor register is maintained and available for audit at any time upon request
- ✓ Any addition of a new sub-processor will be notified to Komet Italia S.r.l. (as Data Controller) with a minimum 30-day advance notice, per standard DPA terms
- ✓ Each sub-processor is evaluated against GDPR Art. 28(3) requirements before engagement
- ✓ Hetzner's ISO 27001 certification provides an independently audited baseline for infrastructure security

10. Technical FAQ for IT

The following addresses the questions most commonly raised by IT departments during technical review of RPA-based systems interfacing with enterprise ERPs.

Q1: Does Formicanera have access to administrative or elevated ERP functions?

No. The system uses exclusively the commercial agent's standard ERP credentials — the same credentials Komet Italia assigned to Mr. Formicola for his standard agent work. It can only access the same screens, functions, and data the agent can access manually. It has no access to ERP configuration, no access to other agents' territories or data, and no administrative functions within the ERP. Elevated permissions are not requested, not obtained, and not technically possible with the agent's credential level.

Q2: Can Formicanera affect ERP performance or stability?

No ERP performance degradation attributable to the system has been observed during the entire operational period. The system is architecturally designed to protect the ERP: it automatically suspends all interaction if the ERP is unresponsive or under maintenance; it spaces data retrieval operations with mandatory intervals; it reduces synchronization frequency automatically when the agent is inactive. The interaction pattern generates less erratic load than a human user — it is predictable, controlled, and never sends aggressive retry loops. The ERP experiences Formicanera as a disciplined, well-behaved user session.

Q3: What happens to the data if the contract is terminated?

All agent-related personal data is erased within 60 days of contract termination. Prior to deletion, a complete structured data export (JSON/CSV) is available to the Controller in accordance with Art. 20 GDPR. Source code access, ERP credentials, and all authentication materials are removed from all Formicanera systems. The DPA will specify the exact post-termination data handling obligations in binding legal form.

Q4: Is the source code auditable?

Yes. A full source code audit can be arranged under NDA at any time. The CI/CD pipeline (GitHub Actions), deployment configuration, and security implementation are all available for review by the Gebr. Brasseler IT team. We consider source code auditability a standard expectation for any responsible enterprise supplier and welcome this level of scrutiny.

Q5: How are ERP credentials protected at rest?

Agent ERP credentials are encrypted using AES-256-GCM with a random IV generated per encryption operation and an authentication tag for tamper detection. The cryptographic material (IV, authentication tag, ciphertext) is serialized separately and stored in the database. The encryption key is derived via PBKDF2-HMAC-SHA256 from an environment variable (ENCRYPTION_KEY) that exists exclusively in the production server environment — it is never present in source code, never in the repository, never in logs, and never transmitted in any API response. Credentials are decrypted on-demand only, in memory, for the duration of the ERP session.

Q6: Does Formicanera generate or modify invoices?

No. The Formicanera system does not generate invoices and applies no financial calculations to invoice data. This is a fundamental architectural principle consistent with the agency contract, under which invoices are issued exclusively by Komet Italia S.r.l. (as the Preponente), not by the agent. All invoices displayed in the application originate exclusively from the Komet ERP — they are downloaded as official PDFs exported by the ERP through the agent's authenticated session and displayed read-only, with no modification possible.

Q7: How is the system monitored for security events?

The system maintains an immutable append-only audit log (PostgreSQL, with application-level write access revoked for UPDATE and DELETE operations). All authentication events, data operations, GDPR actions, and security alerts are recorded with actor ID, IP address, user agent, and timestamp. Automatic alert generation

occurs for repeated failed logins, circuit breaker activation, rate limit breaches, and high-error-rate conditions.
The audit log is inspectable by authorized administrators and available for external audit at any time.

11. Closing Statement

This document provides a complete and verifiable account of the Formicanera system's security architecture, data protection practices, and regulatory compliance posture as of May 2026.

"The Formicanera system was built to fill a genuine operational gap — enabling a field agent to perform his contractual duties more effectively and accurately — while maintaining full consistency with the Komet ERP as the authoritative source of truth. Security and data protection are not features added after the fact: they are **architectural properties of the system**, documented, implemented, and verifiable."

Every security measure documented in this whitepaper is operative in production. Source code, CI/CD pipeline, audit logs, and backup procedures are all available for independent verification under NDA. We do not ask for trust based on assertions — we offer it based on evidence.

We remain fully available for a technical discussion, a live system demonstration, a source code review under NDA, or any additional documentation required by the Gebr. Brasseler GmbH & Co. KG IT and Legal/Compliance teams.

Prepared and signed by:

Francesco Formicola

Developer — Formicanera Agent Management System

On behalf of: Formicola Biagio, Commercial Agent — Komet Italia S.r.l., Cluster 83

Naples, Italy — May 2026

Contact: francesco.formicola@live.it · formicanera.com



Formicanera

Agent Management System — Security & Compliance
Whitepaper

Security & Compliance Whitepaper — Version 2.0 — May 2026

CONFIDENTIAL — For exclusive use of Gebr. Brasseler GmbH &

Co. KG

Prepared by Francesco Formicola · formicanera.com